BOOTCAMP QI TECH 2026 / HACKATHON ANTIFRAUDE PIX

PIX SENTINEL

Documentação técnica completa do motor antifraude contextual.

João Vitor Miranda Sousa | Mohamad Ahmad Barakat

Política vigente: mvp-risk-adaptive-v3-r9

29 sinais

06 famílias

225 testes



README técnico · conteúdo integral diagramado

Esta edição em PDF preserva as descrições, parâmetros, decisões, exemplos e comandos do README enviado. A diagramação adapta tabelas extensas para fichas mais legíveis.

Integrantes: João Vitor Miranda Sousa e Mohamad Ahmad Barakat

Como o motor de decisão funciona

O PIX SENTINEL analisa uma solicitação Pix antes da liquidação e devolve um dos três pareceres: `approved`, `two_factor_required` ou `rejected`.

```
Payload Pix → validação → histórico PostgreSQL → regras de risco → score → decisão
```

A política vigente, `mvp-risk-adaptive-v3-r9`, combina 29 sinais em seis famílias independentes: exposição/velocity, perfil, relacionamento, acesso, temporal e rede do recebedor. Cada família possui um teto para impedir que sinais correlacionados inflem o score. A soma bruta é limitada a 100. Quando uma tipologia determinística exige 2FA, o score operacional recebe piso 25; os pontos originais das famílias permanecem registrados para auditoria.

O histórico usa janelas de 1 minuto, 5 minutos, 15 minutos, 60 minutos e 24 horas. Perfil e referência geográfica consideram somente análises anteriores `approved`; velocity considera todas as tentativas válidas, pois uma tentativa negada também é evidência de ataque.

As janelas incluem a tentativa atual exatamente uma vez. Já expressões como “destinatário nunca visto” consultam apenas eventos anteriores. Assim, o oitavo evento dispara um limiar de oito sem deixar de distinguir primeira observação.

A operação é idempotente: repetir o mesmo `id` e o mesmo payload devolve a decisão persistida; reutilizar o `id` com outros dados retorna `409`. Um lock transacional por pagador protege as contagens concorrentes. O motor não consulta saldo, não movimenta dinheiro e não executa o segundo fator — apenas o recomenda.

No PostgreSQL, o histórico é normalizado em quatro entidades: `accounts`, `devices`, `pix_transactions` e `pix_analyses`. Cada tentativa referencia conta pagadora, conta recebedora e device por chave estrangeira; IP usa o tipo nativo `INET`, geolocalização usa `DOUBLE PRECISION` e o status é um enum. O JSON original continua preservado para auditoria e replay, mas as consultas antifraude usam FKs e colunas tipadas. O diagrama e todas as decisões de modelagem estão no ERD vigente.

Regras

Os valores são heurísticas explicáveis para o hackathon, não probabilidades de fraude. Dentro de exposição, perfil, relacionamento e temporal prevalece o maior nível aplicável; acesso e rede do recebedor podem acumular pontos até o teto da família.

Na dimensão de frequência curta existe apenas a microrrajada de 1 minuto. Uma contagem espalhada por 5 minutos não pontua sozinha; essa janela somente habilita a rajada crítica quando contagem e volume financeiro são simultaneamente altos. Estruturação prevalece sobre o simples total elevado em 60 minutos.

CATÁLOGO DAS 29 REGRAS · R9

01. HIGH_ABSOLUTE_AMOUNT

Hipótese: Valor alto por segmento
Gatilho e peso: PF/indefinido ≥ R$ 5.000; PJ ≥ R$ 15.000; define exposição em 10
Racional: É um alerta leve: nem junto de noite incomum alcança sozinho o limiar de 2FA.

02. VERY_HIGH_ABSOLUTE_AMOUNT

Hipótese: Valor muito alto por segmento
Gatilho e peso: PF/indefinido ≥ R$ 20.000; PJ ≥ R$ 60.000; define exposição em 20
Racional: Mantém cautela para valores excepcionais sem confundi-los com o limite bancário individual.

03. MICROBURST_1M

Hipótese: Muitas tentativas praticamente simultâneas
Gatilho e peso: PF/indefinido ≥ 4; PJ ≥ 6 tentativas em 1 min; define exposição em 25
Racional: É a aceleração mais forte: sozinha já justifica 2FA, com tolerância maior para lotes PJ.

04. ELEVATED_ATTEMPT_TOTAL_60M

Hipótese: Alto volume realmente acumulado
Gatilho e peso: PF/indefinido: ≥ 3 tentativas e R$ 15.000; PJ: ≥ 6 e R$ 50.000 em 60 min; exposição 25
Racional: A contagem mínima impede que um único Pix grande seja contado novamente como agregado.

05. ELEVATED_ATTEMPT_TOTAL_24H

Hipótese: Alto volume diário repetido
Gatilho e peso: PF/indefinido: ≥ 5 tentativas e R$ 50.000; PJ: ≥ 10 e R$ 150.000 em 24 h; exposição 25
Racional: Enxerga ataques lentos sem duplicar o sinal de valor de uma operação isolada.

06. STRUCTURED_AGGREGATE_60M

Hipótese: Contagem e valor elevados juntos
Gatilho e peso: PF/indefinido ≥ 10 tentativas; PJ ≥ 20, junto do total de 60 min do segmento; exposição 35
Racional: Representa fracionamento estruturado e dá mais tolerância ao giro empresarial.

07. CRITICAL_BURST_5M

Hipótese: Rajada crítica de contagem e valor
Gatilho e peso: PF/indefinido: ≥ 12 tentativas e R$ 50.000; PJ: ≥ 20 e R$ 200.000 em 5 min; exposição 60
Racional: Rejeição exige simultaneamente frequência e volume verdadeiramente extremos.

08. FIRST_OBSERVED_YOUNG_SOURCE_ACCOUNT

Hipótese: Cold start material em conta de origem recente
Gatilho e peso: primeira observação local, conta com menos de 30 dias e PF/indefinido ≥ R$ 3.000 ou PJ ≥ R$ 10.000; perfil 15, piso 25 e 2FA
Racional: Compensa a ausência de perfil sem chamar todo cliente novo de fraude.

09. ABOVE_PROFILE_P90

Hipótese: Valor muito acima do percentil habitual
Gatilho e peso: ≥ 2 × p90; eleva perfil para pelo menos 10
Racional: Compara o Pix ao padrão individual, não apenas a um valor fixo.

10. CRITICAL_MEDIAN_DEVIATION

Hipótese: Desvio extremo da mediana
Gatilho e peso: ≥ 8 × mediana; perfil 15, piso 25 e 2FA
Racional: Identifica ruptura forte do comportamento habitual sem rejeitar por uma única anomalia.

11. ELEVATED_MEDIAN_DEVIATION

Hipótese: Desvio relevante da mediana
Gatilho e peso: ≥ 3 × mediana; eleva perfil para pelo menos 10
Racional: Sinaliza mudança de padrão sem rejeitar isoladamente.

12. NEW_COUNTERPARTY

Hipótese: Destinatário novo para o pagador
Gatilho e peso: ≥ 3 tentativas anteriores e contraparte não observada; relacionamento 5; com perfil ≥ 10 aplica piso 25 e 2FA
Racional: Destinos novos têm menos confiança histórica e, junto de ruptura comportamental, representam possível engenharia social.

13. PAIR_REPETITION_15M

Hipótese: Repetição do mesmo par
Gatilho e peso: ≥ 5 tentativas em 15 min; eleva relacionamento para pelo menos 10
Racional: Pode indicar retentativa automatizada ou coerção.

14. CRITICAL_FAN_OUT_60M

Hipótese: Muitos destinatários diferentes
Gatilho e peso: PF/indefinido ≥ 12; PJ ≥ 30 em 60 min; relacionamento 15, piso 25 e 2FA
Racional: Captura dispersão realmente excepcional, com espaço para pagamentos legítimos e lotes PJ.

15. ELEVATED_FAN_OUT_60M

Hipótese: Diversidade elevada de destinatários
Gatilho e peso: PF/indefinido ≥ 6; PJ ≥ 15, abaixo do crítico; relacionamento pelo menos 12
Racional: Antecipa dispersão sem gerar fricção por quatro destinos PF ou uma pequena folha PJ.

16. NEW_DEVICE

Hipótese: Dispositivo não observado para o pagador
Gatilho e peso: ≥ 3 tentativas anteriores; acesso +10
Racional: É um indício de troca de posse ou tomada de conta.

17. NEW_IP

Hipótese: IP não observado para o pagador
Gatilho e peso: ≥ 3 tentativas anteriores; acesso +8
Racional: Acrescenta contexto independente ao dispositivo.

18. CHANNEL_CHANGE

Hipótese: Canal não observado para o pagador
Gatilho e peso: ≥ 3 tentativas anteriores; acesso +5
Racional: Mudança simultânea de canal reforça anomalia de acesso.

19. DEVICE_CHURN_60M

Hipótese: Troca rápida de dispositivos
Gatilho e peso: ≥ 3 dispositivos em 60 min; acesso pelo menos 15
Racional: Sessões legítimas raramente alternam tantos dispositivos em uma hora.

20. IP_CHURN_60M

Hipótese: Troca rápida de IPs
Gatilho e peso: ≥ 3 IPs em 60 min; acesso pelo menos 12
Racional: Pode indicar proxy, automação ou sequestro de sessão.

21. DEVICE_SHARED_ACROSS_PAYERS_60M

Hipótese: Mesmo dispositivo em vários pagadores
Gatilho e peso: ≥ 3 pagadores em 60 min; acesso 15; quando a condição de 2FA é satisfeita, aplica piso 25
Racional: Identifica infraestrutura compartilhada por possível fraudador sem penalizar isoladamente um terminal corporativo; PJ exige também outro contexto de risco.

22. IP_SHARED_ACROSS_PAYERS_60M

Hipótese: Mesmo IP em vários pagadores
Gatilho e peso: ≥ 5 pagadores em 60 min; acesso pelo menos 8
Racional: Ajuda a detectar origem coordenada sem bloquear redes compartilhadas isoladamente.

23. TRANSACTION_CLOCK_SKEW

Hipótese: Horário declarado distante do recebimento
Gatilho e peso: diferença ≥ 2 h; eleva temporal para pelo menos 8
Racional: Detecta payload atrasado, adulterado ou reenviado.

24. UNUSUAL_NIGHTTIME

Hipótese: Operação noturna fora do perfil
Gatilho e peso: 20h–06h em `America/Sao_Paulo`, ≥ 5 amostras e histórico noturno ≤ 20%; eleva temporal para pelo menos 5
Racional: Usa o período noturno de referência do Pix, mas só pontua quando ele foge do hábito do pagador.

25. ELEVATED_GEO_VELOCITY

Hipótese: Deslocamento geográfico improvável
Gatilho e peso: distância ≥ 100 km e velocidade de 300 a 1.000 km/h; eleva temporal para pelo menos 10
Racional: Acrescenta fricção sem tratar viagem plausível como fraude.

26. IMPOSSIBLE_GEO_VELOCITY

Hipótese: Deslocamento geográfico impossível
Gatilho e peso: distância ≥ 100 km e velocidade > 1.000 km/h, ou em até 60 s; temporal 25
Racional: Sugere uso simultâneo ou localização incompatível, mas não rejeita sozinho.

27. RECIPIENT_FIRST_SYSTEM_OBSERVATION

Hipótese: Recebedor nunca visto pelo motor
Gatilho e peso: primeira observação global; rede +5
Racional: Um destino sem histórico local merece cautela moderada.

28. RECIPIENT_FAN_IN_60M

Hipótese: Recebedor concentra muitos pagadores
Gatilho e peso: recebedor PF/indefinido: ≥ 5 pagadores e ≥ 8 tentativas; PJ: ≥ 15 e ≥ 25 em 60 min; rede 15, piso 25 e 2FA
Racional: Detecta possível conta-laranja centralizadora, com limite maior para recebedores empresariais.

29. YOUNG_DESTINATION_ACCOUNT

Hipótese: Conta recebedora recente recebe valor alto
Gatilho e peso: idade de 0 a 6 dias e PF/indefinido ≥ R$ 3.000 ou PJ ≥ R$ 10.000; rede +5; se também for inédita e relação nova, piso 25 e 2FA
Racional: Contas novas de destino apresentam pouco histórico de confiança.

Tetos por família: exposição/velocity 60, perfil 15, relacionamento 15, acesso 20, temporal 25 e rede do recebedor 20. O perfil exige ao menos cinco análises anteriores aprovadas, histórico de 24 horas, mediana positiva e p90 positivo.

Device, IP e geolocalização vêm do payload e não provam identidade. As coordenadas são usadas para calcular distância e velocidade, mas não são copiadas para o snapshot de evidências.

A janela 20h–06h segue o período noturno padrão de referência do Pix. Ela não simula nem aplica o limite bancário individual do cliente, ausente do contrato: é apenas um sinal comportamental fraco, de 5 pontos, e só aparece quando no máximo 20% do histórico aprovado ocorreu nesse período.

O valor absoluto possui dois níveis contextuais. O nível alto soma 10; mesmo com noite incomum (+5), permanece `approved`. O nível muito alto soma 20 e, com noite incomum, alcança 25. Um valor alto comum ainda pode exigir 2FA quando coincide com evidência mais forte, como device e IP novos (+18), ou com ruptura do perfil. Nenhum desses valores representa o limite Pix contratado do cliente.

PF e PJ são inferidos apenas pelo formato normalizado do documento. Valores e dispersão usam limiares segmentados; perfil histórico, acesso e geolocalização continuam com a mesma lógica. Em transferência entre documentos iguais, o motor não pontua novidade do destinatário nem conta recebedora jovem.

Como as regras viram decisão

As salvaguardas são avaliadas nesta ordem:

Prioridade	Condição	Decisão
1	`CRITICAL_BURST_5M`	`rejected`
2	`IMPOSSIBLE_GEO_VELOCITY` e score de acesso ≥ 10	`rejected`
3	score total ≥ 60, pelo menos 4 famílias ativas e acesso ≥ 18 ou rede do recebedor ≥ 15	`rejected`
4	primeira observação local, conta de origem < 30 dias e valor material do segmento	`two_factor_required`
5	`CRITICAL_MEDIAN_DEVIATION` com perfil histórico confiável	`two_factor_required`
6	perfil ≥ 10 e `NEW_COUNTERPARTY`	`two_factor_required`
7	recebedor novo no sistema, conta de destino jovem, relação nova e valor material	`two_factor_required`
8	`RECIPIENT_FAN_IN_60M`	`two_factor_required`
9	`CRITICAL_FAN_OUT_60M`	`two_factor_required`
10	device em ≥ 3 pagadores; isoladamente para PF/indefinido, ou com outro contexto para PJ	`two_factor_required`
11	acesso ≥ 18 junto de relacionamento ou rede do recebedor com risco	`two_factor_required`
12	nenhuma salvaguarda anterior e score total ≥ 25	`two_factor_required`
13	nenhuma salvaguarda anterior e score total < 25	`approved`

As salvaguardas 4 a 11 não alteram os pontos das famílias nem repetem o motor: elas reconhecem tipologias fortes entre sinais já calculados. Quando uma delas exige 2FA e a soma bruta é menor que 25, o score operacional recebe piso 25. O snapshot preserva `base_risk_score`, `risk_score` e informa se o piso foi aplicado. Esse piso nunca habilita rejeição. Uma velocidade impossível isolada, por exemplo, soma 25 e pede 2FA; para rejeitar, ela precisa coincidir com anomalia independente de acesso. Da mesma forma, alcançar 60 pontos não basta: a rejeição por convergência exige quatro famílias e um sinal forte de acesso ou da rede do recebedor.

Quando a decisão é `two_factor_required`, o motor recomenda:

2FA	Quando
`push_confirmation` (`standard`)	Risco suficiente para fricção, sem evidência forte de tomada de conta.
`facial_liveness` (`enhanced`)	Somente PF: acesso ≥ 18 combinado com perfil ≥ 10, relacionamento ≥ 12 ou temporal ≥ 15.

Para PJ e tipo indefinido, o motor nunca recomenda uma "face da empresa": mesmo no contexto reforçado, utiliza `push_confirmation` e deixa a autenticação do operador autorizado para o orquestrador bancário.

O 2FA tem status `recommended`: sua execução e confirmação pertencem ao orquestrador bancário. `approved` não autoriza a liquidação e `rejected` não é prova de fraude.

Para decisões com fricção ou rejeição, `metadata.risk_factors` contém apenas os códigos dos sinais que contribuíram. Score, valores, documentos, IPs e coordenadas permanecem restritos ao snapshot interno.

Exemplo concreto de cálculo

Considere um Pix PF de R$ 6.000 que seja a quarta tentativa em um minuto, feito de um dispositivo e IP novos para um destinatário novo:

```
Exposição
  valor ≥ R$ 5.000 ..... 10
  4 tentativas em 1 min ..... 25
  resultado da família ..... 25  (usa o maior; não soma 10 + 25)

Acesso
  dispositivo novo ..... 10
  IP novo ..... 8
  resultado da família ..... 18  (soma, respeitando o teto 20)

Relacionamento
  destinatário novo ..... 5
```

```
Score total = 25 + 18 + 5 = 48
Decisão     = two_factor_required
2FA         = push_confirmation
```

O motor não soma livremente os dois sinais de exposição porque ambos descrevem o mesmo fenômeno: concentração de risco transacional. Já acesso e relacionamento são evidências diferentes e entram separadamente no score.

Em um caso mais simples, um Pix PF de R$ 6.000 em horário habitual, com acesso e destinatário conhecidos e sem perfil confiável, fica em score 10. Se ocorrer em horário noturno incomum, fica em 15; ambos são aprovados. Já um Pix PF de R$ 20.000 vale 20 e, junto da noite incomum, chega a 25 e recomenda 2FA.

Se um PF com mediana histórica de R$ 100 envia R$ 900 para um destinatário novo, o perfil crítico vale 15 e o relacionamento novo vale 5: a soma bruta é 20. A tipologia de engenharia social aplica piso operacional 25 e ativa `ADAPTIVE_CRITICAL_PROFILE_VERIFICATION`. O resultado é 2FA, nunca rejeição.

O racional completo, incluindo alternativas avaliadas, fórmula, salvaguardas e limitações, está na RFC do motor antifraude. As medições reproduzíveis do endpoint de decisão estão em Estatísticas de tempo da API Pix. Os resultados concretos de 22 situações, as fronteiras de rejeição e as ressalvas de calibração estão em Simulações antifraude e validação das decisões.

Como rodar e testar

Pré-requisito: Docker com Compose.

Suba a API e o PostgreSQL:

```
docker compose up --build -d --wait
docker compose ps
```

Esse comando basta em uma instalação nova. O PostgreSQL só executa `database/database.sql` quando cria o volume pela primeira vez. Se já existir uma base do ERD antigo, faça backup e aplique manualmente `database/005_normalize_accounts_devices_and_types.sql`. Em desenvolvimento, se os dados forem descartáveis, também é possível remover o volume antigo com `docker compose down -v` antes de subir novamente; esse comando apaga a base local.

A API fica em `http://localhost:3000`. `GET /health_check` é público; as rotas Pix usam o header `INTERNAL-TOKEN: default_token`:

- `POST /pix/transaction` analisa e persiste uma tentativa;
- `GET /pix/transaction/{id}` recupera a decisão original sem recalcular.

Teste completo sem skips

Executar apenas `python -m pytest -q` fora do Docker roda os testes unitários, mas pula as integrações que exigem API e PostgreSQL isolados. Além disso, uma instância da API só pode ter uma política ativa por vez. Por isso não seria correto testar expectativas de V1, V2 e R9 contra a mesma configuração.

O Compose resolve isso com uma matriz sequencial. O `pix_test_runner` inicia a API com R9, V1, V2 e V2 R2, executa somente os testes correspondentes e limpa o PostgreSQL entre as etapas. O banco é descartável, nenhuma porta de teste é publicada na máquina e o executor falha se algum teste falhar **ou for pulado**.

Assim, todos os testes podem ser executados com um único comando, sem instalar Python nem configurar `DATABASE_URL` localmente:

```
docker compose -p pix-sentinel-tests -f docker-compose.test.yml up --build
    --abort-on-container-exit --exit-code-from pix_test_runner
```

Os argumentos garantem isolamento e um resultado confiável:

- `-p pix-sentinel-tests` separa os recursos de teste da aplicação normal;
- `-f docker-compose.test.yml` usa apenas a infraestrutura descartável de teste;
- `--build` inclui o código e as dependências atuais nas imagens;
- `--abort-on-container-exit` encerra o banco quando o executor termina;
- `--exit-code-from pix_test_runner` faz o terminal retornar erro se a matriz falhar.

Resultado validado:

```
225 passed, 0 skipped across all policy suites.
```

Ao terminar, remova os contêineres e volumes descartáveis:

```
docker compose -p pix-sentinel-tests -f docker-compose.test.yml down -v
```